Pericope ERM - Complete Feature Guide & Functional Manual

Major Project Authors: Srivatsan B (1AT23CG104), Raja Vishnu (1AT23CG080), Rithvik R (1AT23CG084), Niranthar M Javagal (1AT23CG071)

Academic Guide: Prof. Veena S, Department of Computer Science & Engineering, Atria Institute of Technology

Version: 3.5 (Complete Feature Reference Edition)

1. Platform Overview & Core Architecture

Pericope ERM is an enterprise Governance, Risk, and Compliance (GRC) software suite built on a three-tier, resilience-first architecture:

- **Client Presentation Tier:** Next.js 15 App Router + React 19 + TypeScript + TanStack Query (5-minute TTL caching & exponential backoff) + typed LocalStore engine supporting cross-tab event listeners.
- **Backend-for-Frontend (BFF) Gateway (`server.js`):** Node.js Express API proxy providing input sanitization (keyboard-mash rejection), uppercase Oracle case normalization (`toOracleCase`), strict 8-second circuit-breaker timeout, and an in-memory shadow store fallback.
- **Enterprise Database Tier:** Oracle Autonomous Database (ADW) exposed through Oracle REST Data Services (ORDS) spanning 48 partitioned relational entities with `PRAGMA AUTONOMOUS_TRANSACTION` audit triggers.

2. Executive Dashboard (/dashboard)

The Executive Dashboard acts as the central command center for risk leaders, C-suite executives, and audit committees:

- **Executive Metric Panels (Infolets):**
- **Active Risks:** Total open risks across the enterprise with high/critical severity breakdown.
- **Single Loss Expectancy (SLE):** Real-time financial exposure calculated as SLE = S x $10,000.
- **Control Coverage:** Ratio of cataloged risks with operating internal controls mitigating them (78.4%).
- **Assessment Completion:** Percentage of active departmental RCSA assessment cycles completed.
- **Trailing Risk Velocity Area Chart:**
- Visualizes 6-month historical risk registration and closure trends using smoothed spline curves with area gradients.
- **Risk Allocation by Functional Domain:**
- Breakdown of organizational risk across Information Technology, Finance & Treasury, Vendor Operations, and Legal & Compliance.
- **Live RCSA Case Ledger:**
- High-density operational table displaying recent risk scenarios, assigned departments, financial exposure ($SLE), validation status, and 1-click navigation links.
- **1-Click Board Pack Export Trigger:**
- Direct button routing to executive reporting and PDF generation.

3. RCSA Lifecycle Management (/rcsa/*)

The Risk and Control Self-Assessment (RCSA) module guides risk owners through a standardized 4-stage operational lifecycle:

3.1 Cycle Provisioning & Setup (/rcsa/provisioning)

- **Cycle Scheduling:** Define assessment reference codes (e.g. `RCSA-FIN-2026-001`), target departments, start/end dates, and assigned Risk Champions.
- **Industry Demo Starter Packs:** 1-click seeding of realistic industry templates:
- *Fintech & Banking Starter Pack:* Injects SWIFT payment latency, AML/KYC review, and core banking availability.
- *SaaS & Cloud Security Pack:* Injects SOC 2 readiness, AWS multi-region failover, and GDPR data privacy.
- *Healthcare & HIPAA Pack:* Injects HIPAA patient record security and EHR uptime reviews.
- **Stepper Navigation:** Stage indicator tracking progression across 01 Setup → 02 Identification → 03 Mitigation → 04 Monitoring.

3.2 Assessment Details & Connected Risks (/rcsa/provisioning/[id])

- Dedicated view for a single assessment cycle showing:
- Assessment metadata header with Risk Champion and cycle dates.
- Summary metrics: Connected risks count, total assessment SLE ($), and high-exposure counts.
- Table of risks linked specifically to this assessment.
- "Add Risk to Assessment" modal dialog.
- Direct **"Map Controls →"** action button per risk.

3.3 Risk Identification Register (/rcsa/identification)

- **Risk Statement Cataloging:** Register risk scenarios with department, category, inherent likelihood (1-5), and inherent impact (1-5).
- **Automated Monetary Valuation:** Automatic calculation of Single Loss Expectancy (SLE = L x I x $10,000) and severity band assignment.
- **Sorting & Multi-Column Filtering:** Real-time search by statement, department, and severity.

3.4 Excel / CSV Bulk Spreadsheet Migration Engine

- **Download CSV Template:** Generates `pericope_risk_register_template.csv` with standard column formatting.
- **Import CSV Parser:** Accepts external spreadsheet files, parses quoted CSV strings, validates likelihood/impact numbers, and renders an interactive multi-row preview before importing.
- **1-Click Batch Database Ingest:** Bulk imports parsed records directly into the active risk register.

3.5 Control Mitigation Mapping (/rcsa/mitigation & /rcsa/provisioning/[id]/controls/[riskId])

- **Control Tagging:** Map preventive, detective, and corrective controls to identified risks.
- **Dual-Factor Effectiveness Rating:** Evaluates controls on Design Effectiveness (1-5) and Operating Effectiveness (1-5).
- **Residual Risk Step-Down Engine:** Mathematically calculates the control effectiveness factor eta and computes net residual likelihood, residual impact, and net residual SLE.
- **Action Plan Creator:** Modal to create remediation plans with target dates and owners.

3.6 Continuous Risk Monitoring (/rcsa/monitoring)

- **Remediation Tracking:** Tracks progress percentages (0-100%) on mitigation plans.
- **Milestone Deadlines:** Alerts risk owners on upcoming or overdue remediation targets.

4. Advanced Risk Analytics & Heatmaps

4.1 5x5 Enterprise Risk Heatmap Matrix (/heatmaps)

- **Bi-Axial Coordinate Grid:**
- **Y-Axis (Likelihood):** `5 - Almost Certain (>80%)` down to `1 - Rare (<5%)`.
- **X-Axis (Impact):** `1 - Insignificant (<$25K)` to `5 - Severe (>$1M)`.
- **Multi-View Modes:**
- *Inherent Risk:* Gross pre-control exposure scores.
- *Residual Risk (Post-Control):* Net stepped-down exposure after internal controls.
- *Risk Velocity:* Trailing directional trajectory.
- **Cell-Level Inspection Dialog:** Clicking any cell opens a modal listing the exact underlying risk scenarios.
- **Color-Coded Severity Bands:** Critical (16-25, Rose), High (12-15, Amber), Moderate (8-10, Gold), Low (1-6, Emerald).

4.2 Inherent & Residual Risk Evaluation (/assessments/*)

- **Inherent Risk Form (/assessments/inherent):** Root cause analysis, causal factor taxonomy, data source attribution, and narrative impact statements.
- **Residual Risk Mapping (/assessments/residual):** Quantitative delta analysis between inherent and residual exposure.

4.3 Key Risk Indicators (KRI) Telemetry Hub (/kri)

- **Indicator Master Repository:** Define metrics with units (`hrs/mo`, `%`, `count`, `days`), owners, and measurement frequency.
- **Tri-Color Threshold System:** Green (Normal limit), Amber (Warning bound), and Red (Critical breach threshold).
- **Directionality:** Supports both *Higher-is-worse* (e.g. outage hours) and *Lower-is-worse* (e.g. cash buffer).
- **Live Reading Logger:** Interactive simulator allowing users to input real-time telemetry, immediately updating the status badge (Green → Amber → Red), triggering sparkline trend peaks, and logging audit entries.

4.4 Reports & Board Deliverables Center (/reports)

- **8 Dynamic Report Templates:**
- `RPT-001` — *Executive Board Risk Committee Pack*
- `RPT-002` — *RCSA Assessment Lifecycle Summary*
- `RPT-003` — *SOX Section 404 Control Test Workpapers*
- `RPT-004` — *Immutable Audit Trail Ledger (SOX)*
- `RPT-005` — *Key Risk Indicator (KRI) Threshold Register*
- `RPT-006` — *Control Effectiveness & Residual Risk Report*
- `RPT-007` — *ISO/IEC 27001 Information Security Evidence Pack*
- `RPT-008` — *Third-Party Vendor Risk Assessment (TPRM)*
- **Print / Save as PDF Stylesheet:** Custom `@media print` rules that hide all browser navigation, buttons, search bars, and sidebars, rendering only the clean, full-width executive report.

5. Controls & Governance Center

5.1 Central Control Library (/control-library)

- **Classification Taxonomy:** Categorize controls into Preventive, Detective, Corrective, and Compensating.
- **Nature & Frequency:** Automated, Manual, or Hybrid execution across Continuous, Daily, Weekly, Monthly, Quarterly, and Annual cadences.
- **Multi-Framework Mapping:** Maps controls simultaneously across ISO 27001, SOX Section 404, GDPR, and NIST SP 800-53.
- **Testing Workpapers:** Tracks design scores (1-5) and operational testing scores (1-5).

5.2 Risk Appetite & Tolerance Framework (/risk-appetite)

- **Domain Categories:** Strategic, Financial, Operational, Compliance, IT/Cyber, People, Vendor, and Reputation.
- **Risk Postures:** Averse, Cautious, Open, Hungry.
- **Tolerance vs Exposure:** Numerical tolerance (1-25) compared directly against measured organizational exposure.

5.3 Maker–Checker Approval Workflows (/workflow)

- **Segregation of Duties:** Ensures no single user can both create and approve risk acceptances or policy changes.
- **Multi-Stage Approval Chains:** Routes requests through Assessor → Risk Manager → Administrator.
- **Approval Actions:** Inline Approve and Reject action buttons with audit trail logging.

5.4 Policy Management Center (/policy)

- **Policy Repository:** Document catalog with version control (`v1.0`, `v3.2`), categories, effective dates, and review cadences.
- **Employee Acknowledgment Tracking:** Live percentage gauge tracking workforce policy attestation.

6. Enterprise Risk & Operational Resilience

6.1 Third-Party Risk Management (TPRM / Vendor Risk) (/vendor-risk)

- **Criticality Tiering:** Classify suppliers into Critical, High, Medium, and Low risk tiers.
- **Contract & Risk Scoring:** Track annual contract spend ($), risk scores (1-100), assessment review cadences, and open audit findings.

6.2 Incident & Loss Event Tracker (/incidents)

- **Event Logging:** Log operational loss events with severity (Critical, High, Medium, Low), status (Open, Investigating, Mitigated, Closed), and assigned owners.
- **Root Cause & Remediation:** Capture root cause analysis and corrective action plans linked back to risk registers.

6.3 Business Continuity Planning (BCP / DRP) (/bcp)

- **Continuity Scenarios:** Document recovery plans across core infrastructure, customer support, headquarters site loss, and cyber incidents.
- **RTO & RPO Parameters:** Recovery Time Objective (RTO in hours) and Recovery Point Objective (RPO in hours).
- **Testing Cadence:** Track last tested dates and overdue test warnings.

6.4 Scenario Stress-Testing & FAIR Simulation (/scenario)

- **Probabilistic Shock Modeling:** Model macro shocks (Stress Test, What-if, Reverse Stress, Tail Risk) with shock magnitude percentages.
- **Baseline vs Stressed Loss:** Measure financial delta between baseline operational loss and stressed loss.
- **Simulation Runner:** Execute stress test runs with instant results logging.

7. Administration, Security & Auditability

7.1 Immutable Autonomous Audit Trail (/audit-trail)

- **Non-Repudiation Event Log:** Captures timestamp, user ID, actor name, user role, action type (`CREATE`, `UPDATE`, `DELETE`, `APPROVE`, `ROLE_CHANGE`), target entity, and result.
- **Autonomous Transactions:** Backed by PL/SQL `PRAGMA AUTONOMOUS_TRANSACTION` triggers in Oracle database.
- **CSV Export:** 1-click export of the full audit log for external regulatory examiners.

7.2 User Management & RBAC Security Console (/users)

- **5-Tier Role Hierarchy:**
- *Administrator:* Full platform control, user provisioning, and system settings.
- *Risk Manager:* Maker-checker approvals, mitigation sign-offs, control validation.
- *Assessor:* Risk cataloging, likelihood/impact scoring (no delete).
- *Auditor:* Read-only independent review of workpapers and audit trail.
- *Viewer:* Read-only executive view of heatmaps and reports.
- **User Management:** Add users, reassign roles, toggle active/inactive status, and delete accounts.

7.3 System Configuration & Parameters (/settings)

- **Organization Profile:** Organization name, industry sector, reporting currency (USD, INR, EUR, GBP), and ERM maturity target.
- **Notification Routing:** Email alert thresholds for critical risks and SLA reminders.
- **Security Controls:** Session timeout limits (minutes) and mandatory 2FA policies.
- **Data Retention:** Compliance retention windows for audit logs (7 years SOX) and assessments.

7.4 Multi-Mode Authentication Portal (/login)

- **Corporate Credentials Sign-In:** Username and password authentication.
- **One-Click Role Selection:** Instant testing access across all 5 enterprise personas.
- **Enterprise SSO Simulation:** Single Sign-On simulation for Microsoft Entra ID and Okta.

8. The Mathematical Risk Engine & Quantitative Models

8.1 Qualitative Composite Risk Score

$$S = L \times I \qquad L, I \in \{1, 2, 3, 4, 5\} \quad \Rightarrow \quad S \in [1, 25]$$

8.2 Quantitative Single Loss Expectancy (SLE)

$$SLE = (L \times I) \times \$10{,}000 \quad (USD)$$

8.3 Multi-Factor Residual Risk Weighting

$$\eta = \{Design\ Effectiveness\ (1-5) \times Operating\ Effectiveness\ (1-5)\{25 \in [0.04, 1.0]$$

$$L_{res} = max\left(1, \; round\left(L_{inh} \times (1 - 0.7 \times \eta)\right)\right)$$

$$I_{res} = max\left(1, \; round\left(I_{inh} \times (1 - 0.5 \times \eta)\right)\right)$$

$$Residual\ SLE = (L_{res} \times I_{res}) \times \$10{,}000$$

8.4 Open FAIR Probabilistic Monte Carlo Simulation Engine

- **Loss Event Frequency (LEF):** Modeled as a Poisson process (λ = (L / 5) * 2.5).
- **Loss Magnitude (LM):** Modeled as a Lognormal distribution via Box-Muller transformation.
- **Outputs (10,000 Iterations):** Annualized Loss Expectancy (ALE) and 95% Value at Risk (VaR 95).

8.5 Verification Commands

- **Start Backend Server (Port 5000):** `node server.js`
- **Start Frontend Client (Port 3000):** `npm run dev`
- **Execute QA Verification Suite:** `node qa_test_suite.mjs`
- **TypeScript Typecheck:** `npx tsc --noEmit`